Agent Security Review Kit

The questions banks, insurers and enterprise security teams ask before an AI agent goes into production. For each one: why they ask, what a strong answer looks like, what evidence to attach, and a template answer you can adapt.

Version 0.3.0, updated 2026-10-15. 33 questions in 10 areas, mapped to 16 frameworks. Free to use under CC BY 4.0.

Access & scope

What the agent can do in the buyer's systems, under which identity, and how that is enforced.

ACC-01

What actions can your agent take in our systems, and how are those permissions enforced at the moment a tool is called?

Why buyers ask

The buyer stays responsible for everything that happens in its systems. An agent acting outside its intended authority is a named risk in agent frameworks, and instructions in a prompt are not an enforcement mechanism.

What a strong answer looks like

> Names every tool the agent can call and the scope of each, shows that limits are enforced in code where the tool is invoked (not in the prompt), and offers test results plus a sample action record that shows the scope applied.

Evidence to attach

- Per-agent inventory of tools and actions, with the systems and scopes each one can touch.
- Enforcement in code at the tool-invocation layer (allowlists, parameter validation, scoped credentials), not only in the prompt.
- Test results showing out-of-scope calls are blocked.
- Per-action records that show which scope or permission applied.

Not enough on its own

- The model is instructed not to do X.
- A workflow diagram with no enforcement point.

Template answer

Fill every blank with what your system actually does. If a sentence isn't true for you, delete it and say what you do instead.

> The agent can call _N_ tools: _list tool, target system and allowed operations, e.g. "issue_refund on the payment provider, up to EUR 200 per refund"_. Each call passes through _enforcement layer, e.g. a tool gateway_ that checks _allowlist, parameter limits, scoped credential_ before execution; calls outside scope are _blocked and logged / describe what happens_. We test this in _CI suite / quarterly test_, last run _date_, results attached. Each action record stores _the scope that applied_ (sample attached).

▼ **Framework references (18)**

- **FINOS AIR** AIR-PREV-018: Agent authority least privilege (verified)
- **FINOS AIR** AIR-SEC-024: Risk: agent action authorization bypass (verified)
- **FINOS AIR** AIR-PREV-019: Tool chain validation and sanitization (verified)
- **CSA AICM** IAM-19: Agent access restriction (title only)
- **CSA AICM** AIS-11: Agents security boundaries (title only)
- **CSA AICM** IAM-05: Least privilege (title only)
- **NYDFS 500** 500.7(a): Limit access and privileged accounts to what is needed (verified)
- **NYDFS AI Letter** Access controls: Least privilege and access review apply to AI (verified)
- **ISO 42001** A.9.4: Intended use of the AI system (secondary source)
- **DORA** Art. 9(4): Least-privilege access and strong authentication (verified)
- **SIG** AI domain: Domain-level only; question text not reviewed (title only)
- **AIUC-1** B006: Technical limits on agent actions to authorized scope, with alerting on boundary breaches (verified)
- **AIUC-1** D003.1: Tool call validation and authorization (verified)
- **AIUC-1** A003: Limit agent data access by task, user role, agent role and context (verified)
- **CSA AARM** R1: Intercept actions before execution; denied actions must have no effect, no fail-open mode (verified)
- **CSA AARM** R9: Should scope credentials per action (just-in-time, operation-specific) (verified)
- **SOC 2 TSC** CC6.1: Logical access controls protect information assets (verified)
- **SOC 2 TSC** CC6.3: Access granted by role, with least privilege and segregation of duties (verified)

ACC-02

For every write in our systems, which identity performed it? Which agent and version, under which credential and scope, on whose behalf?

Hard to evidence today

Why buyers ask

Agents often act through shared service accounts or human-style browser logins, so the buyer's own logs cannot tell the agent from a staff member, and the vendor's logs cannot be matched to the buyer's.

What a strong answer looks like

> Each agent deployment has its own non-human identity in the buyer's systems, credentials are kept away from the model, and every action record carries agent ID and version, credential ID, scope and the user, case or ticket it acted for, so the buyer's logs and the vendor's records can be joined.

Evidence to attach

- A distinct non-human identity per agent deployment, visible in the buyer's system logs.
- Each action record carries agent ID and version, credential ID (never the secret), scope, and the initiating user, case or ticket.
- Credentials isolated from the model and injected per call.

Not enough on its own

- A shared integration user for all agent traffic.
- Identity known only inside the vendor's database.

Template answer

Fill every blank with what your system actually does. If a sentence isn't true for you, delete it and say what you do instead.

Agent actions in your [system] run under [a dedicated identity per deployment, name / a shared account: describe], which appears in your audit logs as [identity]. Every action record contains [agent ID, agent version, credential ID (never the secret), scope, initiating user / case / ticket ID]. Credentials are held in [vault / KMS] and [injected per call so the model never sees them / describe how exposure is limited]. A sample record joined to your system log is attached.

▼ Framework references (13)

- **FINOS AIR** AIR-PREV-023: Agentic credential protection, signed agent API requests (verified)
- **FINOS AIR** AIR-DET-021: Log decision initiation, including the triggering event and context (verified)
- **FINOS AIR** AIR-SEC-029: Risk: agent-mediated credential harvesting (verified)
- **CSA AICM** IAM-13: Uniquely identifiable users, including non-human (title only)
- **CSA AICM** IAM-19: Agent access restriction (title only)
- **CSA AICM** LOG-12: Access control logs (title only)
- **NYDFS 500** 500.7(a): Access privileges and management (verified)
- **NYDFS 500** 500.11(b)(1): Third-party access control guidelines (verified)
- **AIUC-1** A003.2: Agent identity management (supplemental) (verified)
- **AIUC-1** E015.2: Agent provenance metadata per execution, e.g. agent type and deployment origin (supplemental) (verified)
- **CSA AARM** R6: Bind each action to human principal, service identity, agent identity and privilege scope (verified)
- **SOC 2 TSC** CC6.2: Users registered and authorized before credentials are issued (verified)
- **SOC 2 TSC** CC6.3: Access granted by role, with least privilege and segregation of duties (verified)

ACC-03

What stops prompt injection or a manipulated tool chain from causing the agent to take an action in our systems?

Why buyers ask

Agents read untrusted content (emails, documents, web pages, tool outputs). If that content can steer a tool call, an attacker can act inside the buyer's systems through the agent.

What a strong answer looks like

> Treats retrieved content as untrusted, filters inputs and outputs, validates tool choice and parameters before execution independently of the model, has red-team results that include indirect injection, and can detect unusual actions after the fact.

Evidence to attach

- Separation of instructions from untrusted data, plus input and output filtering.
- Validation of tool selection and parameters before execution.
- Red-team results that include indirect injection through retrieved content.
- Detection of out-of-pattern actions in the action records.

Not enough on its own

- We use a safe model.

Template answer

Fill every blank with what your system actually does. If a sentence isn't true for you, delete it and say what you do instead.

> Untrusted content (emails, documents, web pages, tool outputs) is kept separate from instructions by method , and inputs and outputs are filtered by method . Before any tool call, validator checks tool choice and parameters against policy ; how you prevent the model from bypassing it, and how that is tested . Our last red-team exercise on date , by internal team / third party , covered direct and indirect injection ; a summary is attached. Unusual actions are flagged by rule / monitor .

▼ Framework references (13)

- **FINOS AIR** AIR-SEC-025: Risk: tool chain manipulation and injection (verified)
- **FINOS AIR** AIR-SEC-010: Risk: prompt injection (verified)
- **FINOS AIR** AIR-PREV-019: Tool chain validation and sanitization (verified)
- **FINOS AIR** AIR-PREV-003: User/app/model firewalling and filtering (verified)
- **CSA AICM** AIS-15: Prompt differentiation (title only)
- **CSA AICM** AIS-08 / AIS-09: Input and output validation (title only)
- **CSA AICM** MDS-06 / MDS-07: Adversarial attack analysis and robustness (title only)
- **NIST AI 600-1** MS-2.7-007: Red-team for prompt injection and related attacks (verified)
- **NIST AI RMF** MEASURE 2.7: Security and resilience evaluated and documented (verified)
- **EU AI Act** Art. 15(5): Resilience against manipulation of inputs and outputs (high-risk) (verified)
- **AIUC-1** B002: Detect and respond to adversarial inputs and prompt injection attempts (verified)
- **AIUC-1** B005: Filter inputs before they reach the model (verified)
- **CSA AARM** R3: Evaluate each action against static policy and alignment with the user's stated intent (verified)

Action records

What is recorded for each agent action, and whether one action can be produced end to end.

ACT-01

For any single agent action, can you produce the complete record? What triggered it, which inputs and sources it used, the exact tool call and arguments, the system's response, and the downstream effect.

Hard to evidence today

Why buyers ask

Reviewers and examiners pick one case and ask you to walk through it. If the record is spread across chat transcripts, APM traces and the vendor UI, the answer takes days and cannot be checked.

What a strong answer looks like

> Can pick any action and produce, in minutes, one record with trigger, inputs and sources, exact tool call and arguments, the system's response, timestamps and trace ID, with sensitive fields redacted.

Evidence to attach

- A per-action record with trigger, inputs, retrieved sources, tool name, arguments (redacted where needed), the system response, timestamps and a trace ID.
- A sample export for one real (redacted) case, produced on request in minutes.

Not enough on its own

- A chat transcript without the tool calls.
- Infrastructure logs only.

Template answer

Fill every blank with what your system actually does. If a sentence isn't true for you, delete it and say what you do instead.

> Every action produces one record containing: trigger (event / user request), inputs and retrieved sources, tool name and arguments (with fields redacted), the target system's response, timestamps and trace ID. We can export the full record for any action or case within time . A redacted example for one real case is attached.

▼ Framework references (14)

- **FINOS AIR** AIR-DET-021: Log inputs, reasoning, tool selection, actions taken and downstream effects (verified)
- **CSA AICM** LOG-11: Transaction/activity logging (title only)
- **CSA AICM** LOG-08: Log records contain relevant security information (secondary source)
- **CSA AICM** LOG-14 / LOG-15: AI input and output monitoring (title only)

- **EU AI Act** Art. 12(1)-(2): Automatic event logging over the lifetime that enables traceability (high-risk) (verified)
- **ISO 42001** A.6.2.8: AI system recording of event logs (secondary source)
- **NYDFS 500** 500.6(a)(1): Systems able to reconstruct material financial transactions (verified)
- **NAIC AI Bulletin** Sec. 3, 3.3(b)-(c): Model documentation, traceability and auditability (verified)
- **NYDFS CL7** ¶19: Be able to explain at all times how the AIS operates (verified)
- **AIUC-1** E015: Mandatory logging of AI system processes, actions and agent outputs for investigation and audit (verified)
- **AIUC-1** E015.2: Tool call parameters and results, sub-agent delegations, approvals and reasoning traces (supplemental) (verified)
- **AIUC-1** D003.3: Tool call log (verified)
- **CSA AARM** R5: Signed receipt per action with tool, parameters, context, identity, decision and outcome (verified)
- **SOC 2 TSC** PI1.3: Controls over processing (processing integrity, if in scope) (verified)

ACT-02

Which model and version handled a given action, including actions served by versions you have since retired?

Hard to evidence today

Why buyers ask

Vendors route between several models and providers. When a past decision is challenged, the buyer must know which model produced it, even if that model is gone.

What a strong answer looks like

> Stores the provider, model name and pinned version on every action record, and keeps an inventory of retired versions with the dates they were in use.

Evidence to attach

- Model provider, model name and pinned version stored on every action record.
- A model inventory that keeps retired versions with their active dates.

Not enough on its own

- A current list of providers with no per-action version.

Template answer

Fill every blank with what your system actually does. If a sentence isn't true for you, delete it and say what you do instead.

> Each action record stores model provider, model name and pinned version, e.g. example . We keep a model inventory including retired versions and their active dates (link / attachment), so any past action can be matched to the model that handled it.

▼ Framework references (8)

- **FINOS AIR** AIR-PREV-010: AI model version pinning (verified)
- **FINOS AIR** AIR-OP-005: Risk: foundation model versioning (verified)
- **NIST AI 600-1** GV-1.6-003: Inventory records underlying models and versions (verified)
- **NIST AI RMF** GOVERN 1.6 / 1.7: AI inventory and decommissioning (verified)
- **NAIC AI Bulletin** Sec. 3, 3.3(a): Model inventory (verified)
- **NYDFS CL7** ¶29: Inventory including retired AIS, with change tracking (verified)
- **CSA AICM** MDS-03 to MDS-05: Model documentation (title only)
- **CSA AICM** MDS-09: Model signing and ownership verification (title only)

ACT-03

Show every model endpoint and external service the agent actually called for our traffic, not just the list in your inventory.

Hard to evidence today

Why buyers ask

An inventory says what should be called. Destination records show what was called, which is what data-flow and data-residency reviews need.

What a strong answer looks like

> Records each outbound call per action (provider, endpoint, region) and periodically compares actual destinations with the declared sub-processor list for that buyer.

Evidence to attach

- Per-action record of each outbound call (provider, endpoint, region).
- A periodic summary per buyer comparing actual destinations with the declared sub-processor list.

Not enough on its own

- A static sub-processor page.

Template answer

Fill every blank with what your system actually does. If a sentence isn't true for you, delete it and say what you do instead.

> Each action record lists the outbound calls made: provider, endpoint, region . Every month / quarter we compare actual destinations for your traffic with the declared sub-processor list and share the result. The latest comparison is attached.

▼ Framework references (7)

- **CSA AICM** STA-16: Service bill of materials (title only)
- **CSA AICM** DSP-05: Data flow documentation (title only)
- **FINOS AIR** AIR-DET-004: AI system observability, centralized logs (verified)
- **FINOS AIR** AIR-PREV-020: Log all MCP traffic (verified)
- **NYDFS AI Letter** Monitoring: Monitor AI tool use for unusual query behaviour (verified)
- **DORA** Art. 30(2)(b): Contract specifies data processing locations and notice of changes (verified)
- **AIUC-1** E009: Log third-party API connections, sessions and data access (verified)

ACT-04

Which documents and records contributed to each answer or action?

Why buyers ask

Reviewers need to trace an output back to its sources, both to check correctness and to confirm the agent only used data it was entitled to see.

What a strong answer looks like

> Stores the ID and version of each document or record the agent used, and retrieval respects the access controls of the source system.

Evidence to attach

- Source IDs (document, record, version) stored on the action record.
- Entitlement checks that carry the source system's access controls into retrieval.

Not enough on its own

- Citations shown in the UI but not retained.

Template answer

Fill every blank with what your system actually does. If a sentence isn't true for you, delete it and say what you do instead.

> For each answer or action we store the IDs and versions of the sources used (document IDs, record IDs). Retrieval runs under the requesting user's permissions / a scoped identity , so the agent only sees what that user / that scope is entitled to. An example record with sources is attached.

▼ Framework references (4)

- **FINOS AIR** AIR-DET-013: Citations and source traceability (verified)
- **FINOS AIR** AIR-DET-016: Preserve source data access controls (verified)
- **CSA AICM** DSP-20: Data provenance and transparency (title only)
- **ISO 42001** A.7.5: Data provenance (secondary source)

ACT-05

What is the lineage of the data used in a decision? Where did each input come from, and how current was it?

Why buyers ask

Insurance and lending regulators ask for data lineage, and stale or wrong inputs are a common root cause of bad decisions.

What a strong answer looks like

> Documents data flows per use case and stores, with each decision, where every input came from and when it was retrieved.

Evidence to attach

- Documented data flows per use case.
- Input source and retrieval timestamp stored with the decision.

Not enough on its own

- A generic architecture diagram.

Template answer

Fill every blank with what your system actually does. If a sentence isn't true for you, delete it and say what you do instead.

> For _use case_, inputs come from _sources_. A data-flow diagram is attached. With each decision we store the source and retrieval time of every input, so you can see how current the data was at the time.

▼ Framework references (5)

- **NAIC AI Bulletin** Sec. 3, 3.2: Data practices incl. lineage and integrity (verified)
- **NYDFS CL7** ¶29: Documentation of inputs and their sources (verified)
- **ISO 42001** A.7.5: Data provenance (secondary source)
- **CSA AICM** DSP-20: Data provenance and transparency (title only)
- **NIST AI 600-1** GV-6.1-008: Records of third-party content changes with sources and timestamps (verified)

ACT-06

For an adverse decision, can you give the specific reasons and the data relied on? A proprietary model is not an acceptable reason to withhold them.

Why buyers ask

Consumer-facing lenders and insurers must give specific reasons for adverse outcomes, and regulators reject vendor secrecy as an excuse.

What a strong answer looks like

> Stores reason codes and the specific inputs relied on for each decision, and can produce an explanation for a specific adverse outcome from that record.

Evidence to attach

- Reason codes and the specific inputs relied on, stored per decision.
- A sample adverse-decision explanation produced from the stored record.

Not enough on its own

- Global feature importance for the model.

Template answer

Fill every blank with what your system actually does. If a sentence isn't true for you, delete it and say what you do instead.

> For each decision we store reason codes (list or link) and the specific inputs relied on. An explanation for an individual adverse outcome is generated from that stored record, not reconstructed later. A redacted sample is attached.

▼ Framework references (6)

- **NYDFS CL7** ¶39-¶40: Reasons include all information relied on; no proprietary-algorithm excuse (verified)
- **NYDFS CL7** ¶44: Written reasons within 15 days in specified cases (verified)
- **EU AI Act** Art. 86(1): Right to explanation for affected persons (Annex III) (verified)
- **NIST AI RMF** MEASURE 2.9: Explain and interpret output in context (verified)
- **CSA AICM** GRC-13 / GRC-14: Explainability requirement and evaluation (title only)
- **FINOS AIR** AIR-OP-017: Risk: lack of explainability (verified)

ACT-07

For customer-facing agents, can you show per interaction that the conduct rules for our use case were met, such as AI disclosure, contact-time windows and contact-frequency limits?

Hard to evidence today

Why buyers ask

In collections, servicing and sales, a single non-compliant contact can be a violation. Buyers want per-interaction proof, not a policy that the platform enforces rules.

What a strong answer looks like

> Records, per interaction, the disclosure given, the local time of contact, the contact count at that moment and the rule version applied, so compliance can be shown for any single contact.

Evidence to attach

- Per-interaction record of the disclosure given, the time in the customer's time zone, and the frequency counter at the time of contact.
- Rule configuration and version applied to each interaction.

Not enough on its own

- QA reviews a sample of calls.

Template answer

Fill every blank with what your system actually does. If a sentence isn't true for you, delete it and say what you do instead.

> For each interaction we record the AI disclosure given (wording), the time in the customer's time zone, the contact-frequency count at that moment, and the version of the rule set applied (rule set). An export for a sample of N interactions is attached.

The specific conduct rules (for example debt-collection contact limits) come from the sector law for your use case and are not mapped here.

▼ **Framework references (3)**

- **EU AI Act** Art. 50(1): Inform people they are interacting with an AI system (verified)
- **CSA AICM** LOG-11: Transaction/activity logging (title only)
- **AIUC-1** E016: Disclose AI interaction (text, voice) and when autonomous agents perform actions (verified)

Outcome verification

Whether what the agent reports matches what actually happened in the system of record.

OUT-01

When the agent says it did something, how do you know it actually happened in our system, as described?

Hard to evidence today

Why buyers ask

An agent's own summary ("refund issued") is not evidence. Agents can report success while the target system shows an error, a different amount or nothing at all. Reviewers want the system of record's response next to the claim.

What a strong answer looks like

> Stores the agent's claim next to the target system's actual response, optionally reads the object back from the system of record to confirm, and reports the mismatch rate to the buyer.

Evidence to attach

- Each action record stores both the agent's claim and the target system's actual response (status, object ID, returned values).
- Optional read-back that queries the system of record and records match or mismatch.
- Mismatch rate per period, reported to the buyer.

Not enough on its own

- The agent's final message.
- HTTP 200 without checking the returned object.

Template answer

Fill every blank with what your system actually does. If a sentence isn't true for you, delete it and say what you do instead.

> Each action record stores both what the agent reported and the response from _target system_ (status, object ID, returned values). For _high-impact actions, e.g. refunds_ we also read the object back from _system_ and record match or mismatch. The mismatch rate for _period_ was _x_ (_report attached_).

▼ Framework references (8)

- **FINOS AIR** AIR-DET-021: Log actions taken and their downstream effects (verified)
- **NYDFS 500** 500.6(a)(1): Reconstruct material financial transactions (verified)
- **EU AI Act** Art. 12(2): Logs enable traceability and deployer monitoring (verified)
- **NAIC AI Bulletin** Sec. 3, 3.4: Validate and retest outputs after implementation (verified)
- **NIST AI RMF** MEASURE 2.4: Monitor behaviour in production (verified)
- **AIUC-1** E015.2: Tool call results logged alongside parameters (supplemental) (verified)
- **CSA AARM** R5: Receipt includes execution result and error details, not only the decision (verified)
- **SOC 2 TSC** PI1.4: Output delivered completely and accurately (processing integrity, if in scope) (verified)

OUT-02

How do you detect and report actions that failed, only partly completed, or produced a different result than intended?

Hard to evidence today

Why buyers ask

Silent failures are the hardest to catch. A buyer wants to see failures counted and reported, not discovered by a customer.

What a strong answer looks like

> Counts failed, partial and mismatched actions per period with examples, has alert thresholds and owners, and reconciles high-impact actions against the system of record.

Evidence to attach

- Failed, partial and mismatched actions counted per period, with examples, in the buyer's report.
- Alert thresholds and owners.
- Reconciliation against the system of record for high-impact actions.

Not enough on its own

- Error rate from APM only.

Template answer

Fill every blank with what your system actually does. If a sentence isn't true for you, delete it and say what you do instead.

> Failed, partial and mismatched actions are counted and included in your _monthly_ report with examples. Alerts fire at _threshold_ and go to _owner_. For _action types_ we reconcile against _system_ every _period_. The last report is attached.

▼ Framework references (8)

- **CSA AICM** LOG-13: Failures and anomalies reporting (title only)
- **CSA AICM** MDS-11: Model failure (title only)
- **FINOS AIR** AIR-DET-004: Observability and alerting on anomalies (verified)
- **NIST AI 600-1** MG-4.3-002: Track errors, near-misses and negative impacts (verified)
- **ISO 42001** A.6.2.6: AI system operation and monitoring (secondary source)
- **DORA** Art. 17(1)-(3): Detect, log, classify and track ICT incidents (verified)
- **SOC 2 TSC** PI1.3: Controls over processing (processing integrity, if in scope) (verified)
- **SOC 2 TSC** CC7.2: Monitor components for anomalies and evaluate them (verified)

Tamper evidence

Whether records can be changed after the fact without anyone noticing, and who can check.

TMP-01

Are agent action records protected so that any edit, deletion, reordering or truncation after the fact is detectable?

Hard to evidence today

Why buyers ask

Access controls protect logs from outsiders, not from the party that writes them. "Immutable" is a claim; reviewers increasingly ask for the mechanism.

What a strong answer looks like

> Names the mechanism: hash-chained, signed records with keys separated from operators, periodic commitments (for example Merkle roots) so edits, deletions, reordering and truncation are all detectable, and synchronized clocks.

Evidence to attach

- Hash-chained, append-only records (each record commits to the previous one).
- Digital signatures with keys separated from application operators.
- Periodic commitment of segment digests (for example a Merkle root) so truncation is detectable.
- Synchronized clocks and documented key management.

Not enough on its own

- "Logs are immutable" with no mechanism.
- Write-protected storage alone, where the vendor still controls the storage.

Template answer

Fill every blank with what your system actually does. If a sentence isn't true for you, delete it and say what you do instead.

Action records are _append-only and hash-chained, each record including the hash of the previous one / describe_. Records are signed with _algorithm_ keys held in _KMS / HSM_, _separate from the people who run the agent / describe_. Every _period_ we commit a digest of the latest records _to an external log / to you_, so _truncation is also detectable / describe_. Clocks are synchronized via _time source_. Key management is documented in _document_.

▼ Framework references (13)

- **FINOS AIR** AIR-DET-021: Tamper-evident logging and immutable records; names hash chaining and signed segments (verified)

- **FINOS AIR** AIR-PREV-024: Tamper-evident approval record; hash chaining alone is not non-repudiation (verified)
- **DORA** RTS 2024/1774 Art. 12: Protect logging systems and log information against tampering and deletion (secondary source)
- **CSA AICM** LOG-09: Protect audit records from modification and deletion (secondary source)
- **CSA AICM** IAM-12: Safeguard logs integrity (secondary source)
- **CSA AICM** LOG-02: Audit logs protection (secondary source)
- **CSA AICM** LOG-06: Clock synchronization (title only)
- **NIST AI 600-1** MS-2.8-003: Tamper-proof history of generated content (content provenance) with version control (verified)
- **NYDFS 500** 500.6(a): Securely maintain audit trail systems (no cryptographic requirement) (verified)
- **AIUC-1** E015.4: Tamper-evident logs; gaps, omissions and reordering detectable (supplemental) (verified)
- **CSA AARM** R5: Cryptographically signed receipts for all actions, over a canonical serialization (verified)
- **CSA AARM** R2: Should keep session context as an append-only, hash-chained log (verified)
- **SOC 2 TSC** PI1.5: Stored inputs and outputs kept complete and accurate; names no tamper-evidence mechanism (verified)

TMP-02

Can we, our auditor or our regulator verify those records ourselves, without access to your systems and without relying on your word?

Hard to evidence today

Why buyers ask

Logs the vendor writes, stores and attests to are self-reported evidence. The strongest records are those a third party can check independently.

What a strong answer looks like

> Gives the buyer an exported bundle and a verification tool they run themselves, offline, with documented public keys and digests anchored outside the vendor, plus a demo of a tampered bundle failing.

Evidence to attach

- A verification tool the buyer can run offline on an exported bundle.
- Public keys and verification steps documented.
- Record digests anchored outside the vendor (for example an append-only transparency log) or held by the buyer.
- A worked example showing a tampered bundle failing verification.

Not enough on its own

- A screenshot or PDF export from the vendor's UI.
- A SOC 2 report, which covers controls, not individual records.

Template answer

Fill every blank with what your system actually does. If a sentence isn't true for you, delete it and say what you do instead.

> To verify records yourself, you [run verifier, e.g. an open-source CLI, offline against an exported bundle / describe current process] using our published public key [key ID]. Segment digests are anchored in [external log / your storage], so [what a rewrite of history would show, and to whom]. A sample bundle, the verification steps and a tampered example that fails are attached.

FINOS, AIUC-1 (E015.4, supplemental) and CSA AARM (R5, offline-verifiable signatures) state independent verifiability explicitly. Elsewhere it follows from audit and access rights.

▼ Framework references (5)

- **FINOS AIR** AIR-DET-021: Records verifiable by deployer, auditor or authority without privileged access to the provider; anchoring to a transparency log (verified)
- **DORA** Art. 30(3)(e): Unrestricted rights of access, inspection and audit (critical or important functions) (verified)
- **EU AI Act** Art. 13(3)(f): Mechanisms that let deployers collect, store and interpret logs (high-risk) (verified)
- **AIUC-1** E015.4: Logs independently verifiable (supplemental); no verification method specified (verified)
- **CSA AARM** R5: Receipt signatures verifiable offline with published public keys (verified)

TMP-03

Who at your company can read, change or delete agent records, and is that access itself logged?

Why buyers ask

Privileged insiders are the main threat to record integrity. Reviewers expect named roles and an access trail.

What a strong answer looks like

> Lists the named roles with access to record storage and signing keys, logs each access against an individual identity, and separates people who run the agent from people who can touch records or keys.

Evidence to attach

- Named roles with access to record storage and keys.
- Access to records logged against individual identities and reviewed.
- Separation between people who run the agent and people who can touch records or keys.

Not enough on its own

- "Only engineers have access."

Template answer

Fill every blank with what your system actually does. If a sentence isn't true for you, delete it and say what you do instead.

> Access to record storage is limited to _roles, number of people_; access to signing keys to _roles_. Every access is _logged against an individual identity and reviewed every period / describe_. People who operate the agent _cannot change records or keys / describe the separation_. The latest access review is attached.

▼ Framework references (6)

- **CSA AICM** LOG-04: Audit log access restricted and attributable (secondary source)
- **CSA AICM** IAM-12: Logging infrastructure read-only to those with other write access (secondary source)
- **CSA AICM** IAM-04: Separation of duties (title only)
- **NYDFS 500** 500.7(c): Privileged access monitoring (Class A companies) (verified)
- **AIUC-1** E015.3: Log storage with access controls, retention and sanitation (verified)
- **SOC 2 TSC** CC6.3: Access granted by role, with least privilege and segregation of duties (verified)

Incident reconstruction

Detecting, reporting, stopping and reconstructing what went wrong.

INC-01

After an incident, can you reconstruct exactly what the agent did, in which of our systems, under which identity, and in what order?

Hard to evidence today

Why buyers ask

Incident response, root-cause analysis and regulator notifications all depend on an ordered, complete account. Gaps are what turn an incident into a finding.

What a strong answer looks like

> Can export, for any time window or case, an ordered account of every action across the buyer's systems, with evidence that the sequence is complete and unaltered, and knows from a test how long that takes.

Evidence to attach

- For a time window or case, an ordered export of all actions across all buyer systems, with identity, scope, inputs and system responses.
- Evidence the sequence is complete (no gaps) and unaltered.
- A tabletop exercise or test showing how long reconstruction takes.

Not enough on its own

- Our engineers can query the database.

Template answer

Fill every blank with what your system actually does. If a sentence isn't true for you, delete it and say what you do instead.

For any time window or case we can export _every agent action across systems_, in order, with _identity, scope, inputs and system responses_. _Mechanism, e.g. a hash chain plus externally committed digests_ shows the exported sequence has not been altered or cut short. In our last tabletop on _date_, a full reconstruction took _time_.

▼ Framework references (13)

- **FINOS AIR** AIR-DET-021: Tier 1 is reconstruction of what happened (verified)
- **NYDFS 500** 500.6(a): Audit trails to reconstruct transactions and respond to cybersecurity events (verified)
- **NYDFS 500** 500.16(a)(1): Incident response plan incl. documentation and root cause (verified)
- **DORA** Art. 17(1)-(3): Incident detection, logging and root-cause analysis (verified)
- **DORA** Art. 30(2)(f): Provider assists with ICT incidents (verified)

- **EU AI Act** Art. 73: Serious incident reporting; provider must not alter the system before informing authorities (verified)
- **CSA AICM** SEF-09: Incident response (title only)
- **CSA AICM** LOG-05 / LOG-06: Audit log monitoring and clock synchronization (title only)
- **NIST AI RMF** MANAGE 4.3: Track and recover from incidents and errors (verified)
- **AIUC-1** E015: Logs must support incident investigation and explanation of behaviour (verified)
- **AIUC-1** E001: Breach plan covers evidence collection and preservation for legal review (verified)
- **CSA AARM** R5 / R6: Receipts with identity binding support forensic reconstruction of actions (verified)
- **SOC 2 TSC** CC7.4: Respond to incidents: understand, contain, remediate, communicate (verified)

INC-02

How do you detect and report model failures, data leakage or harmful outputs, and on what timeline will we hear about them?

Why buyers ask

The buyer has its own notification clocks (72 hours under NYDFS 500, 4 hours from classification and at most 24 hours from awareness under DORA). Vendor timelines must fit inside them.

What a strong answer looks like

> Commits in the contract to a notification timeline that fits inside the buyer's own regulatory clocks, names the detection sources and owners, and can show a recent incident or tabletop record.

Evidence to attach

- Contractual notification timeline that fits the buyer's obligations.
- Detection sources (monitoring, alerts, user reports) and owners.
- A recent incident report or tabletop record (redacted).

Not enough on its own

- A generic incident-response policy with no AI-specific triggers.

Template answer

Fill every blank with what your system actually does. If a sentence isn't true for you, delete it and say what you do instead.

> We detect _model failures, data leakage, harmful outputs_ through _monitoring, alerts, user reports_, owned by _team_. We notify you within _hours_ of detection, as set out in _contract clause_, which fits within _your NYDFS / DORA timelines_. A redacted incident or tabletop report from _date_ is attached.

▼ **Framework references (15)**

- **NYDFS 500** 500.11(b)(3): Third-party notice of cybersecurity events (verified)
- **NYDFS 500** 500.17(a): Notify DFS within 72 hours, incl. third-party incidents (verified)
- **NYDFS AI Letter** Risk assessments: Incident and continuity plans should address AI-related events (verified)
- **DORA** Art. 19; RTS 2025/301: Major ICT incident reporting and time limits (secondary source)
- **EU AI Act** Art. 73(2)-(6): Serious incident reporting deadlines (high-risk) (verified)
- **CSA AICM** SEF-07: Security breach notification (title only)
- **CSA AICM** MDS-11: Model failure (title only)
- **ISO 42001** A.8.4: Communication of incidents (secondary source)
- **NIST AI 600-1** MG-4.3-002: Track errors and negative impacts (verified)
- **FINOS AIR** AIR-DET-001: AI data leakage prevention and detection (verified)
- **FS-ISAC GenAI** Levels 2-3: Vulnerability management, DLP and log management in deeper due diligence (verified)
- **AIUC-1** E001: Failure plan for AI privacy and security breaches with notification procedures (verified)
- **AIUC-1** E002: Failure plan for harmful outputs with customer communication protocols (verified)
- **SOC 2 TSC** CC7.3: Evaluate security events to decide whether they are incidents (verified)
- **SOC 2 TSC** CC2.3: Communicate with external parties on matters affecting internal control (verified)

INC-03

How quickly can we stop the agent, or roll it back to a previous model or configuration?

Why buyers ask

When something goes wrong the first question is how to stop it. Rollback also matters when a provider changes a model underneath you.

What a strong answer looks like

> Gives the buyer a kill switch it can trigger itself with a tested time to effect, and a documented rollback path to a pinned earlier model, prompt and configuration.

Evidence to attach

- A kill switch the buyer can trigger, with tested time to effect.
- Pinned model and prompt versions with a documented rollback path.
- Results of the last rollback test.

Not enough on its own

- Contact support.

Template answer

Fill every blank with what your system actually does. If a sentence isn't true for you, delete it and say what you do instead.

> You can stop the agent yourself via _console button / API / revoking credential_, taking effect within _time_ (tested _date_). Model, prompt and configuration versions are pinned, and we can roll back to _previous version_ within _time_. Results of the last stop and rollback test are attached.

▼ Framework references (9)

- **EU AI Act** Art. 14(4)(e): Ability to interrupt the system with a stop procedure (high-risk) (verified)
- **NIST AI RMF** MANAGE 2.4: Mechanisms to supersede, disengage or deactivate (verified)
- **NIST AI 600-1** MG-2.4-002 / MG-2.4-004: Escalation and deactivation criteria (verified)
- **CSA AICM** CCC-09: Change restoration (title only)
- **FINOS AIR** AIR-PREV-010: Model version pinning (verified)
- **ISO 42001** A.6.2.5: AI system deployment plan (secondary source)
- **DORA** Art. 28(7)-(8); Art. 30(3)(f): Termination rights, exit plans and transition (verified)
- **NYDFS 500** 500.16(a): Incident response and continuity plans (verified)
- **SOC 2 TSC** CC7.5: Recover from identified security incidents (verified)

Retention

How long records are kept, by whom, and how the buyer gets them.

RET-01

What do you log about agent activity, how long do you keep it, who can access it, and can you export it to our SIEM or GRC tool?

Why buyers ask

Log management is an explicit topic in the deepest tier of bank AI due diligence. Short default retention is a common finding.

What a strong answer looks like

> Lists the agent-level events logged (not just infrastructure), the retention per log type, who can access them, and offers an export into the buyer's SIEM or GRC tool with a sample.

Evidence to attach

- A list of logged event types for agent actions (not just infrastructure).
- Retention period per log type.
- Export mechanism (API or scheduled delivery) and a sample export.

Not enough on its own

- "Logs retained for 30 days" with no agent-action logs.

Template answer

Fill every blank with what your system actually does. If a sentence isn't true for you, delete it and say what you do instead.

We log _event types: actions, tool calls, outcomes, reviews, config changes_. Retention: _period per type_. Access: _roles_. You can receive records via _API / scheduled delivery / your SIEM or object storage_ in _format_. A sample export is attached.

▼ Framework references (10)

- **FS-ISAC GenAI** Level 3: Log management, audit validation and data retention (verified)
- **CSA AICM** LOG-01 / LOG-02 / LOG-07: Logging policy, protection and scope (secondary source)
- **DORA** RTS 2024/1774 Art. 12: Define logged events and retention (secondary source)
- **ISO 42001** A.6.2.8: AI system recording of event logs (secondary source)
- **FINOS AIR** AIR-DET-004: Centralize AI logs, for example in a SIEM (verified)
- **NYDFS AI Letter** Monitoring: Monitor user activity and AI tool use (verified)
- **SIG** AI domain: Domain-level only; question text not reviewed (title only)
- **AIUC-1** E015.3: Log storage with defined retention periods, access controls and PII masking (verified)

- **CSA AARM** R8: Should stream telemetry to SIEM in a standard schema (OCSF, CEF) plus batch export (verified)
- **SOC 2 TSC** CC7.2: Monitor components for anomalies and evaluate them (verified)

RET-02

Can we hold our own copy of the agent's event logs for the period our rules require?

Hard to evidence today

Why buyers ask

Under the EU AI Act, deployers of high-risk systems must keep the logs that are under their control for at least six months, and financial institutions keep them under their financial-services record rules. A buyer-held copy is how a deployer shows it meets that, rather than depending on the vendor.

What a strong answer looks like

> Delivers records continuously or on a schedule into storage the buyer controls, in a documented format that stays verifiable without the vendor.

Evidence to attach

- Continuous or scheduled delivery of records into storage the buyer controls.
- Format documented so the buyer's copy remains verifiable on its own.

Not enough on its own

- We can send logs on request.

Template answer

Fill every blank with what your system actually does. If a sentence isn't true for you, delete it and say what you do instead.

> Records are delivered _continuously / every period_ to _your bucket / SIEM / storage_, which you control. The format is documented (_link_) and each copy can be verified on its own, without access to our systems. You set retention there to match your rules.

EU AI Act Annex III high-risk obligations (including credit scoring and life/health insurance pricing) apply from 2 Dec 2027 after the Digital Omnibus, Regulation (EU) 2026/1744.

▼ Framework references (5)

- **EU AI Act** Art. 26(6): Deployer keeps logs at least six months; financial institutions under financial law (high-risk) (verified)
- **EU AI Act** Art. 19(1)-(2): Provider keeps logs it controls at least six months (verified)
- **EU AI Act** Art. 12(1): Automatic logging over the lifetime (verified)
- **NYDFS 500** 500.6(b): Covered entity keeps audit-trail records five years (verified)
- **CSA AARM** Sec. VI.D: Vendor-side integrations must let customers export or receive receipts for their audit trail (verified)

RET-03

How do we get timely access to our data and to reports on the agent's activity, by type and frequency?

Why buyers ask

Buyers must be able to monitor the service and to give data to auditors and regulators on demand.

What a strong answer looks like

> Names the report types and cadence in the contract and lets the buyer export its own data and records without a support ticket.

Evidence to attach

- Report types and cadence in the contract (activity, failures, incidents, changes).
- Self-service export of the buyer's data and records.

Not enough on its own

- A dashboard with no export.

Template answer

Fill every blank with what your system actually does. If a sentence isn't true for you, delete it and say what you do instead.

You receive activity, failure, incident and change reports every period, as defined in contract section. You can export your data and agent records at any time via self-service export / API.

▼ Framework references (5)

- **DORA** Art. 30(2)(d): Access to and return of data in an accessible format (verified)
- **DORA** RTS 2024/1773 Art. 3: Effective data access for auditors and authorities (secondary source)
- **EU AI Act** Art. 13(3)(f): Log collection mechanisms described for deployers (verified)

- **ISO 42001** A.8.5: Information for interested parties (secondary source)
- **NAIC AI Bulletin** Sec. 4, 1.1-1.3: Documents regulators may request (verified)

RET-04

Does the retention of agent records match our own record-keeping obligations, and what happens to the records when the contract ends?

Why buyers ask

Vendor defaults (often weeks) rarely match the buyer's retention duties (often years). On exit, the buyer still needs the records.

What a strong answer looks like

> Lets each buyer set retention to its own obligations and commits, on exit, to return records in a verifiable format before deleting them.

Evidence to attach

- Retention configurable per buyer, set to the buyer's requirement.
- Exit clause covering return of records in a verifiable format before deletion.

Not enough on its own

- A fixed vendor-wide retention period.

Template answer

Fill every blank with what your system actually does. If a sentence isn't true for you, delete it and say what you do instead.

> Retention is configurable per customer; for you it is set to _period_ to match _your obligation_. On termination we return all records in _format_, verifiable without us, within _days_, and delete our copies after your confirmation, per _contract clause_.

▼ Framework references (5)

- **NYDFS 500** 500.6(b): Five-year retention for covered entities' audit trails (verified)
- **EU AI Act** Art. 19(2); Art. 26(6): Financial institutions keep logs under financial-services documentation rules (verified)
- **DORA** Art. 28(8); Art. 30(2)(d): Exit plans and return of data (verified)
- **NAIC AI Bulletin** Sec. 3, 3.6: Data and record retention in the AIS program (verified)
- **SOC 2 TSC** C1.2: Dispose of confidential information per objectives (confidentiality, if in scope) (verified)

Model & prompt changes

Which models run, how changes are controlled, and how behaviour is monitored over time.

CHG-01

Which foundation models and providers sit behind each feature, and how will you notify us when they change?

Why buyers ask

The model is the most important sub-component. Silent model swaps change behaviour and can invalidate the buyer's validation.

What a strong answer looks like

> Lists models and providers per feature with versions, commits contractually to advance notice of changes, and keeps a change log the buyer can see.

Evidence to attach

- Model and provider list per feature, with versions.
- Contractual advance notice of model or provider changes.
- Change log available to the buyer.

Not enough on its own

- We use leading LLMs.

Template answer

Fill every blank with what your system actually does. If a sentence isn't true for you, delete it and say what you do instead.

Feature : _provider, model, version_ . _Feature_ : _provider, model, version_ . We give _N days_ advance notice of any model or provider change, per _contract clause_ . The change log is at _link_ .

▼ Framework references (9)

- **FS-ISAC GenAI** Level 1: Identify the foundation model (verified)
- **NIST AI 600-1** GV-1.6-003; GV-6.2-007: Inventory of models and versions; contracts address liability for changes over time (verified)
- **FINOS AIR** AIR-PREV-007: Contracts cover model versioning and change notification (verified)
- **FINOS AIR** AIR-PREV-010: Advance notice of new versions and deprecations (verified)

- **CSA AICM** CCC-05; STA-08; STA-16: Change agreements, supply chain inventory, service BOM (title only)
- **NYDFS AI Letter** Data management: Inventory of all systems that use or rely on AI (verified)
- **DORA** Art. 28(3): Register of ICT third-party arrangements (verified)
- **ISO 42001** A.4.4; A.10.3: Tooling resources; suppliers (secondary source)
- **SOC 2 TSC** CC3.4: Vendor assesses changes that could affect its controls; says nothing about notifying customers (verified)

CHG-02

How are changes to prompts, agent logic, tools and models tested, approved and versioned before they reach our traffic?

Why buyers ask

For agents, a prompt edit is a code change. Buyers want the same change control they expect for software.

What a strong answer looks like

> Versions prompts, tools and configs like code, runs evaluations before release with a named approver, stores the version on every action record, and gives the buyer a change history it can review.

Evidence to attach

- Versioned prompts, tool definitions and configs, with the version stored on each action record.
- Pre-release evaluation results and a named approver per change.
- Change history the buyer can review.

Not enough on its own

- Prompts edited in a vendor console with no history.

Template answer

Fill every blank with what your system actually does. If a sentence isn't true for you, delete it and say what you do instead.

> Prompts, tool definitions and configs are versioned in `repository`. Every change runs `evaluation suite` and needs approval from `role` before release. The active version is stored on each action record. Change history for your deployment is available at `link`.

▼ Framework references (12)

- **FS-ISAC GenAI** Level 3: Change management (verified)
- **CSA AICM** CCC-01 to CCC-09: Change control and configuration management (title only)
- **NYDFS CL7** ¶17; ¶29: Test on material changes; track changes with approvers (verified)
- **DORA** Art. 9(4): Recorded, tested and approved ICT changes (verified)
- **ISO 42001** A.6.2.4; A.6.2.5: Verification and validation; deployment (secondary source)
- **NIST AI RMF** MANAGE 4.1: Post-deployment monitoring incl. change management (verified)
- **FINOS AIR** AIR-PREV-005: System acceptance testing (verified)
- **FINOS AIR** AIR-PREV-025: Skill and plugin integrity (verified)
- **NIST AI 600-1** MS-2.8-003: Version control across the lifecycle (content provenance) (verified)
- **AIUC-1** E004: Define changes needing approval (model, system prompt, guardrails); named approver and records (verified)
- **AIUC-1** C002: Pre-deployment testing of changes with risk assessment and approval sign-off (verified)
- **SOC 2 TSC** CC8.1: Changes authorized, designed, tested, approved and documented (verified)

CHG-03

How is the agent validated, independently or on an ongoing basis, including drift and bias testing?

Why buyers ask

Banks and insurers apply model risk management to vendor models. They need validation evidence they can file.

What a strong answer looks like

> Shares the validation method and latest results (including bias testing where consumers are affected), drift monitoring with re-validation triggers, and any independent validation report.

Evidence to attach

- Validation methodology and latest results, including bias testing where decisions affect consumers.
- Drift monitoring and re-validation triggers.
- Any independent validation report.

Not enough on its own

- Marketing benchmark numbers.

Template answer

Fill every blank with what your system actually does. If a sentence isn't true for you, delete it and say what you do instead.

> We validate _agent / model_ using _method_; latest results from _date_ are attached, including bias testing on _dimensions_ where decisions affect consumers. Drift is monitored by _metric_; re-validation is triggered by _condition_. _Independent validation by X on date / none yet_.

▼ Framework references (7)

- **FS-ISAC GenAI** Level 2: Model validation (verified)
- **NAIC AI Bulletin** Sec. 3, 3.3(c); 3.4: Drift and auditability; validation and retesting (verified)
- **NYDFS CL7** ¶15-¶17; ¶32: Testing and independent review (verified)
- **NIST AI RMF** MEASURE 2.3 / 2.5 / 2.11: Performance, validity and fairness (verified)
- **CSA AICM** MDS-10; GRC-11; A&A-02: Continuous monitoring, bias assessment, independent assessments (title only)
- **ISO 42001** A.6.2.4: Verification and validation (secondary source)
- **FINOS AIR** AIR-DET-015: LLM-as-a-judge evaluation calibrated to humans (verified)

CHG-04

What ongoing monitoring do you report to us? Performance, error rates, complaints and drift.

Why buyers ask

Third-party oversight is continuous, not a one-time review. The buyer needs regular data to show its own supervisors.

What a strong answer looks like

> Sends a recurring report with defined metrics and thresholds (performance, errors, complaints, drift) and escalates when a threshold is breached.

Evidence to attach

- A recurring report with defined metrics and thresholds.
- Escalation when thresholds are breached.

Not enough on its own

- Ad-hoc updates on request.

Template answer

Fill every blank with what your system actually does. If a sentence isn't true for you, delete it and say what you do instead.

> Every _period_ you receive a report covering _performance, error rate, mismatch rate, complaints, drift_ against agreed thresholds. Breaches are escalated to _contact_ within _time_. A sample report is attached.

▼ Framework references (8)

- **NIST AI RMF** GOVERN 1.5; MEASURE 2.4; MANAGE 4.1: Planned and post-deployment monitoring (verified)
- **EU AI Act** Art. 72: Post-market monitoring by the provider (high-risk) (verified)
- **ISO 42001** A.6.2.6: Operation and monitoring (secondary source)
- **CSA AICM** MDS-10: Model continuous monitoring (title only)
- **DORA** Art. 30(3)(a): Precise service levels and reporting (verified)
- **NYDFS CL7** ¶29-¶30: Monitoring, drift testing and complaints (verified)
- **FINOS AIR** AIR-DET-011: Human feedback loop (verified)
- **AIUC-1** C008: Ongoing monitoring of AI outputs across risk categories (verified)

Data handling

Training use, retention and deletion of buyer data, including inside agent records.

DAT-01

Is our data used to train or improve any model? How long are prompts, uploads and outputs kept, and how is deletion verified?

Why buyers ask

The first AI question in almost every questionnaire. Buyers also check that the vendor's model providers make the same commitment.

What a strong answer looks like

> States in the contract that buyer data is not used for training, by the vendor or its model providers, gives the retention per data type, and confirms deletion on request.

Evidence to attach

- Contract terms on no training and on retention, including for model providers (zero retention where available).
- Retention schedule per data type.
- Deletion procedure and a deletion confirmation on request.

Not enough on its own

- A privacy policy page.

Template answer

Fill every blank with what your system actually does. If a sentence isn't true for you, delete it and say what you do instead.

> Your data _is not used / is used, under these conditions:_ to train or improve any model, by us or by _providers_, per _contract clause / provider terms_. Retention: prompts _period_, uploads _period_, outputs _period_; _zero-retention terms with providers where available_. Deletion follows _procedure_, and we _confirm it in writing on request_.

▼ Framework references (10)

- **FS-ISAC GenAI** Category 2: Data privacy, retention and deletion (verified)
- **NYDFS AI Letter** Data management: Dispose of NPI no longer needed, including NPI used for AI (verified)
- **NYDFS 500** 500.11(b)(4): Third-party representations and warranties (verified)
- **CSA AICM** DSP-02; DSP-12; DSP-15; DSP-16: Disposal, purpose limitation, production data use, retention and deletion (title only)
- **DORA** Art. 30(2)(c): Contract provisions on data integrity and confidentiality (verified)
- **FINOS AIR** AIR-RC-001: Risk: information leaked to hosted model (verified)
- **NIST AI 600-1** MG-4.1-006: Track dataset deletions and rectifications (verified)
- **AIUC-1** A001: Input data policy on training use, retention and customer rights; enforced retention and deletion (verified)
- **AIUC-1** A002: Output ownership, opt-out and deletion policy (verified)
- **SOC 2 TSC** C1.2: Dispose of confidential information per objectives (confidentiality, if in scope) (verified)

DAT-02

What personal or confidential data ends up inside your agent action records, and how is it minimized, redacted or protected?

Why buyers ask

Detailed action records are a second copy of customer data. Reviewers will ask the same data questions about the records as about the product.

What a strong answer looks like

> Redacts or hashes sensitive fields before records are stored, documents the data classes per record field, and applies the same access and retention rules to records as to the product.

Evidence to attach

- Field-level redaction or hashing of sensitive arguments before records are stored.
- Documented data classes per record field.
- Access and retention rules for records match the data policy.

Not enough on its own

- Full request and response bodies logged by default.

Template answer

Fill every blank with what your system actually does. If a sentence isn't true for you, delete it and say what you do instead.

> Before a record is stored, _fields, e.g. card numbers, account numbers_ are _redacted / hashed_. The data classes per record field are documented in _document_. Records follow the same access and retention rules as your other data with us.

▼ Framework references (8)

- **NYDFS AI Letter** Data management: Data minimization (verified)
- **FINOS AIR** AIR-PREV-014: Encryption of AI data at rest (verified)
- **FINOS AIR** AIR-DET-001: Data leakage prevention and detection (verified)
- **CSA AICM** DSP-12: Limitation of purpose (title only)
- **DORA** Art. 30(2)(c): Data confidentiality provisions (verified)
- **AIUC-1** A006: Prevent personal data leakage through outputs and logs (verified)
- **AIUC-1** E015.3: Data sanitation in log storage (verified)
- **SOC 2 TSC** C1.1: Identify and maintain confidential information (confidentiality, if in scope) (verified)

Human oversight (as the buyer defines it)

Evidence that the oversight model the buyer chose was actually followed.

HUM-01

Under the oversight model we define for this use case, which agent actions need human review, and can you show that the review happened whenever it was required?

Hard to evidence today

Why buyers ask

The buyer chooses how much oversight a use case needs (by risk, amount, customer impact). What it needs from the vendor is evidence that its chosen model was followed, including that review came before execution where the buyer requires that.

What a strong answer looks like

> Expresses the buyer's oversight rules as readable configuration, records per action whether review applied, who reviewed, the decision and its timing relative to execution, and reports exceptions.

Evidence to attach

- Oversight rules expressed as configuration the buyer can read and change.
- Per-action record showing whether review applied, who reviewed, the decision, and its timing relative to execution.
- An exceptions report for actions that should have been reviewed but were not.

Not enough on its own

- A workflow screenshot.
- A statement that "humans are in the loop".

Template answer

Fill every blank with what your system actually does. If a sentence isn't true for you, delete it and say what you do instead.

Your oversight rules are configured as _rules, e.g. review for refunds above EUR X_, visible and editable by you in _place_. For each action the record shows whether review applied, who reviewed, the decision, and the time of review relative to execution. Actions that should have been reviewed but were not appear in _exceptions report_.

▼ Framework references (12)

- **NAIC AI Bulletin** Sec. 3 (risk factors): Extent of human involvement in final decisions (verified)
- **NYDFS AI Letter** Training: When human review must be part of verification (verified)
- **NIST AI RMF** GOVERN 3.2; MAP 3.5: Human-AI roles and oversight processes defined (verified)
- **EU AI Act** Art. 14: Human oversight measures for high-risk systems (verified)
- **FINOS AIR** AIR-PREV-024: Where a gate is used, a tamper-evident approval record bound to the action (verified)
- **CSA AICM** GRC-15; IAM-04: Human supervision; separation of duties (title only)
- **ISO 42001** A.9.2: Processes for responsible use (secondary source)
- **AIUC-1** D003.4: Human approval for sensitive tool operations (core control since Oct 2026) (verified)
- **AIUC-1** E015.2: Approval records linked to execution: approver, timestamp, decision (supplemental) (verified)
- **AIUC-1** C007: Flag high-risk outputs for human review (verified)
- **CSA AARM** R4: STEP_UP blocks the action until an approver decides; deny on timeout recommended (verified)
- **CSA AARM** R5: Receipt records approver identity, decision and timestamp (verified)

HUM-02

What audit trail exists when a person overrides, corrects or reverses what the agent did or recommended?

Why buyers ask

Overrides show where the agent is wrong and who took responsibility. Both matter in a dispute.

What a strong answer looks like

> Links each override to the original action with who, when, what changed and why, and reports override rates over time.

Evidence to attach

- Override records linked to the original action, with who, when, what changed and why.
- Override rates reported over time.

Not enough on its own

- Overrides visible only as a later edit in the target system.

Template answer

Fill every blank with what your system actually does. If a sentence isn't true for you, delete it and say what you do instead.

> When someone overrides, corrects or reverses an agent action, we record who, when, what changed and why, linked to the original action record. Override rates are included in your period report.

▼ Framework references (5)

- **NIST AI RMF** MANAGE 4.1; MEASURE 3.3: Appeal and override in monitoring; feedback channels (verified)
- **EU AI Act** Art. 14(4)(d): Overseers can disregard, override or reverse output (high-risk) (verified)
- **CSA AICM** IAM-18: Output modification and special authorization (title only)
- **FINOS AIR** AIR-DET-011: Human feedback loop (verified)
- **AIUC-1** C009: Real-time user intervention; intervention logs reviewed (supplemental) (verified)

Sub-processors

Model, voice and tool providers behind the agent, and the buyer's audit and regulator rights.

SUB-01

Which model, voice, speech-to-text, text-to-speech and tool providers are involved, and what are their data retention and training terms?

Why buyers ask

Nth-party risk is its own category in bank AI due diligence. Each provider is another place customer data can go.

What a strong answer looks like

> Publishes a complete sub-processor list that includes AI, voice and tool providers with region and purpose, with each provider's retention and training terms, and a change notice process.

Evidence to attach

- Complete sub-processor list including AI providers, with region and purpose.
- Each provider's retention and training terms.
- Notice process for sub-processor changes.

Not enough on its own

- "No subprocessors available."

Template answer

Fill every blank with what your system actually does. If a sentence isn't true for you, delete it and say what you do instead.

> Sub-processors involved in the agent: provider, purpose, region, retention, training terms for each of model, speech-to-text, text-to-speech and tools. The full list is at link. We notify you N days before adding or changing one.

▼ Framework references (11)

- **FS-ISAC GenAI** Category 6: Nth-party risk and usage (verified)
- **NYDFS 500** 500.11(a): Third-party service provider security policy (verified)
- **NYDFS AI Letter** TPSP and vendor management: Diligence on third parties' AI (verified)
- **CSA AICM** DSP-14; STA-08; STA-09; STA-16: Sub-processor disclosure, supply-chain inventory and risk, service BOM (title only)
- **ISO 42001** A.10.2; A.10.3: Allocating responsibilities; suppliers (secondary source)
- **NIST AI RMF** GOVERN 6.1; MAP 4.1: Third-party AI risk policies and component mapping (verified)
- **DORA** Art. 28(3); Art. 30(2)(b); RTS 2025/532: Register, locations, subcontracting conditions (secondary source)
- **FINOS AIR** AIR-SEC-026: Risk: MCP server supply chain compromise (verified)
- **AIUC-1** E006: Due diligence on foundation and upstream model providers: data handling, PII, security (verified)
- **AIUC-1** E011: Document AI data processing locations (verified)
- **SOC 2 TSC** CC9.2: Assess and manage risks from vendors and business partners (verified)

SUB-02

What audit rights or audit reports cover the AI system itself, not just your infrastructure?

Hard to evidence today

Why buyers ask

Insurers and banks are expected to secure audit rights over third-party AI. A SOC 2 report usually covers infrastructure and access, not agent behaviour.

What a strong answer looks like

> Grants audit rights that cover the AI system itself and provides reports whose scope includes agent behaviour, together with record samples the buyer can verify.

Evidence to attach

- Audit-rights clause covering the AI system.
- Reports whose scope includes agent behaviour, plus record samples the buyer can verify.

Not enough on its own

- A SOC 2 report alone.

Template answer

Fill every blank with what your system actually does. If a sentence isn't true for you, delete it and say what you do instead.

> _Contract clause_ gives you audit rights over the AI system, including _model use, agent actions, records_. Our _SOC 2 Type II / other report_ covers _scope_. For agent behaviour we provide verifiable record samples for any period you choose.

▼ Framework references (6)

- **NAIC AI Bulletin** Sec. 3, 4.2(a); 4.3: Audit rights or audit reports; exercise of audit rights (verified)
- **NYDFS CL7** ¶37: Audit rights or reports in vendor contracts (verified)
- **DORA** Art. 28(6); Art. 30(3)(e): Audits; access, inspection and audit rights (verified)
- **FS-ISAC GenAI** Level 3: Audit validation (verified)
- **CSA AICM** A&A-02: Independent assessments (title only)
- **NIST AI 600-1** GV-6.1-006: Clauses allowing evaluation of third-party processes (verified)

SUB-03

Will you cooperate with regulatory inquiries and give examiners access to the documentation and records they ask for?

Why buyers ask

Regulators examine the buyer, and through the buyer, its AI vendors. Buyers need the cooperation in writing and the artifacts ready.

What a strong answer looks like

> Commits in writing to cooperate with regulators and keeps an evidence package ready: model documentation, validation, change history and verifiable action records.

Evidence to attach

- Regulatory cooperation clause.
- A ready evidence package: model documentation, validation, change history and verifiable action records.

Not enough on its own

- Best-effort cooperation with no artifacts.

Template answer

Fill every blank with what your system actually does. If a sentence isn't true for you, delete it and say what you do instead.

> Contract clause commits us to cooperate with your regulators and to give examiners access to documentation and records. We keep an evidence package ready: model documentation, validation results, change history and verifiable action records, deliverable within time.

▼ Framework references (5)

- **NAIC AI Bulletin** Sec. 3, 4.2(b); Sec. 4: Cooperation with regulatory inquiries; documents regulators may request (verified)
- **NYDFS CL7** ¶9; ¶37: DFS exam authority; cooperation clause (verified)
- **DORA** Art. 30(2)(g): Full cooperation with competent authorities (verified)
- **EU AI Act** Art. 18: Provider documentation kept for authorities (verified)
- **ISO 42001** A.8.5: Information for interested parties incl. regulators (secondary source)

How the references were checked

Each framework reference is marked *verified* (checked against the primary text), *secondary source* (primary is gated, checked against a reliable secondary source) or *title only*. Paraphrases are ours and short; read the source before relying on one. This kit is not legal advice and does not certify compliance with anything.

Frameworks

- FINOS AI Governance Framework Live site incl. v2.0 agentic additions (accessed 2026-10-14)
- FS-ISAC Generative AI Vendor Risk Assessment Guide February 2024 (guide; question workbook not public)
- NAIC Model Bulletin on the Use of Artificial Intelligence Systems by Insurers Adopted 2023-12-04
- NYDFS Cybersecurity Regulation, 23 NYCRR Part 500 As amended 2023-11-01
- NYDFS Industry Letter, Cybersecurity Risks Arising from Artificial Intelligence 2024-10-16
- NYDFS Insurance Circular Letter No. 7 (AIS and ECDIS in underwriting and pricing) 2024-07-11
- CSA AI Controls Matrix (AICM) and AI-CAIQ v1.0.3 control titles; v1.1 (Jul 2026) has 247 controls and 320 AI-CAIQ questions
- ISO/IEC 42001:2023 AI management system, Annex A 2023
- NIST AI Risk Management Framework 1.0 (NIST AI 100-1) January 2023
- NIST AI 600-1 Generative AI Profile July 2024
- EU AI Act, Regulation (EU) 2024/1689 As amended by the Digital Omnibus on AI, Regulation (EU) 2026/1744; Annex III high-risk obligations apply from 2027-12-02
- Digital Operational Resilience Act, Regulation (EU) 2022/2554, and its RTS Applies from 2025-01-17; RTS 2024/1773, 2024/1774, 2025/301, 2025/532
- Shared Assessments Standardized Information Gathering (SIG) questionnaire SIG 2026 (AI risk domain since SIG 2024; ISO 42001 mapping added in 2026)
- AIUC-1, the AI agent standard (Artificial Intelligence Underwriting Company) October 15, 2026 release (quarterly; next due 2027-01-15)
- Autonomous Action Runtime Management (AARM) specification, Cloud Security Alliance AARM Working Group v1.0, February 2026 (arXiv:2602.09433); donated by Vanta to CSA 2026-04-30; v2.0 planned
- AICPA Trust Services Criteria (SOC 2) 2017 criteria with revised points of focus (2022); criteria text checked against the AICPA 2020 edition, criteria unchanged in 2022

Maintained by Gleipnir. Suggest a question you were asked in a real review on GitHub.